

Tribal Digital Estate | Sovereign Data Protection Controls Matrix

Encryption and key management. Companion to the [Data Sovereignty Workbook](#). Initial version published for TribalNet 2026.

How to use this matrix

Start on the Controls page. Classify each system into a sensitivity tier based on your own tribe's data/risk posture/internal policies, then read across to the recommended posture for each control. Use the four platform sheets (AWS, Azure, GCP, Salesforce) to compare the native key management options that deliver that posture. Bring the vendor questions on this page to any procurement conversation. This is a reference matrix, not a hand fillable worksheet.

Sensitivity tiers			
Tier	Examples	Required key posture	Tier band
Tier 1 - Sovereign Data	Enrollment and citizenship records, language, ceremonial and sacred knowledge, health, genetic and biometric data, land records	Hold Your Own Key or equivalent required. A breach would cause irreparable harm to members and the sovereign relationship.	
Tier 2 - Sensitive Data	Staff HR, financial and legal records, grant management, internal governance communications	Strong customer managed key or single tenant HSM. A breach would be serious but manageable.	
Tier 3 - General Data	Public communications, event management, non sensitive correspondence, operational records	Standard cloud. No additional key management overhead required.	

Key custody models (the sovereignty spectrum)			
Model	Who holds the key	Cloud provider access	CLOUD Act risk to provider
Provider Managed (PMK)	Cloud provider	Full	High
Customer Managed (BYOK / CMK)	Customer generates; provider stores after import	Technical access retained	Moderate to High
Hold Your Own Key (HYOK)	Customer; key never enters the cloud	None	Low
Split Key / Dual Key	Both parties hold one key each (both persistent)	Cannot access alone	Low for provider copy alone
Cache-Only / Ephemeral	In cloud memory transiently; never persisted	None or time limited	Very Low

Note: after import, a BYOK key sits in the provider environment, so its practical exposure is close to Provider Managed. The advantage of BYOK over PMK is lifecycle control and audit visibility, not legal protection.

Tribal Digital Estate | Sovereign Data Protection Controls Matrix

Encryption and key management. Companion to the [Data Sovereignty Workbook](#). Initial version published for TribalNet 2026.

Starter questions to bring to any vendor

1	After we provide our encryption key, where exactly does it reside, and does that change after a corporate acquisition?
2	Can you be compelled by law enforcement to use our key to decrypt our data without our knowledge? Provide your published government access policy URL.
3	Have you received a CLOUD Act, FISA, or National Security Letter demand? (Silence is treated as confirmation of a gag order.)
4	Is <i>Hold Your Own Key</i> or External Key Management available, and which external key managers are certified compatible?
5	What is your FIPS 140-3 certificate number? (Not whether you are FIPS certified. The certificate number.)
6	If our external key service goes down, what exactly stops working, and how fast? Secondly, what features or functionality will be degraded or unavailable when processing encrypted data?
7	Does your standard Terms of Service license our data for AI training or product improvement, and can that clause be removed?
8	Will you notify our tribal government directly before responding to any government data request, to the maximum extent the law permits?

Acronyms used in this matrix

PMK	Provider Managed Key	DKE	Double Key Encryption (Microsoft 365)
BYOK / CMK	Bring Your Own Key / Customer Managed Key	KMS	Key Management Service
HYOK	Hold Your Own Key	HSM	Hardware Security Module
XKS	External Key Store (AWS)	DEK / KEK	Data Encryption Key / Key Encryption Key
CMEK	Customer Managed Encryption Key (GCP)	CLOUD Act	Clarifying Lawful Overseas Use of Data Act (US)
EKM	External Key Management	FIPS	Federal Information Processing Standard
CSEK	Customer Supplied Encryption Key (GCP)	TEE	Trusted Execution Environment
KAJ	Key Access Justifications (GCP)	CASB	Cloud Access Security Broker

Scope note: third party and CASB key managers are out of scope as controls in this matrix. They appear only as the external key manager that enables a given posture, on the Use-Case block of the Controls page. See Section 9 of the white paper for the full third party analysis. Cloud capabilities change quickly. Verify FIPS certificate numbers, KAJ support, and post quantum status against current vendor documentation before procurement.

This matrix is provided for informational purposes and reflects our assessment of the vendor landscape as of the date shown; platform capabilities change frequently, so verify each vendor's current technical controls and certifications directly, and consult your own technical and legal advisors, before making any procurement or deployment decision.

[Open Sovereignty Lab / 580 Strategies, Working Draft, September 2026.](#)

Controls by Tier and by Use-Case

Classify the system, then read across to the recommended posture. Third party enablers are reference only, not included in analysis in this version.

Block A. Recommended posture by sensitivity tier			
Control	Tier 1 Sovereign Data	Tier 2 Sensitive Data	Tier 3 General Data
Data residency and applicable law	Keep the system of record on tribal controlled or sovereign edge infrastructure, or use HYOK so no provider can decrypt regardless of region. Provider nationality, not data center location, governs CLOUD Act exposure.	Provider region acceptable with a negotiated data processing agreement. Understand that geography does not reduce CLOUD Act exposure.	Standard provider region. No special residency requirement.
Encryption and key custody (who holds the keys)	HYOK or equivalent. AWS XKS, GCP Cloud EKM with KAJ, or Salesforce EKM or Cache-Only Key. The key encryption key stays outside the cloud.	Strong customer managed key or single tenant HSM. AWS CloudHSM Custom Key Store or Azure Managed HSM; Salesforce EKM.	Standard customer managed key. AWS CMK, Azure Key Vault, GCP CMEK, or Salesforce Standard Shield.
Access control and identity	Zero trust and just in time access. Require multi party (M of N) approval for high privilege key operations. No standing credentials.	Role based access with least privilege and multi factor authentication. Prefer RBAC over legacy access policies.	Standard single sign on with multi factor authentication.
AI training opt-out	Explicit written prohibition on using your data, or patterns drawn from it, to train or improve vendor models. Retain the right to verify.	Written opt-out from AI training and product improvement in the contract.	Review the default terms. Remove any training clause you do not want.
Sub-processors	Approve every sub-processor that can touch the data. Require notice and approval before any new one is added.	Maintain the current sub-processor list. Require notice of changes.	Review the published sub-processor list at onboarding.
Portability and exit	Documented full export in an open format, plus a tested kill switch by key destruction. Note the waiting periods: AWS 7 to 30 days, GCP minimum 24 hours, Salesforce Tenant Secret destruction is permanent.	Documented export path with a defined time and format. Confirm what breaks if the external key service is offline.	Standard export. No special exit engineering.
Audit and monitoring	Log every key request, including the requester and justification, to tribal controlled immutable storage. Monitor the external key manager in real time.	Enable logging (off by default in Azure; CloudTrail must be configured in AWS) and route it to protected storage.	Standard platform logging.

Controls by Tier and by Use-Case

Classify the system, then read across to the recommended posture. Third party enablers are reference only, not included in analysis in this version.

Block B. Common tribal use cases

Use case	Recommended architecture (native platforms)	External key manager that enables the posture (reference only, not a control)	Key caution
Enrollment and citizenship (Tier 1)	Highest sensitivity. Salesforce EKM or Cache-Only Key with a tribal controlled HSM, or a custom application on AWS with XKS and an on premises or managed HSM. Where feasible, keep the system of record on tribal infrastructure and use Salesforce External Objects so the data is viewed, not stored.	Tribal HSM on tribal land; Thales Luna, Entrust nShield, or Fortanix as the external key manager.	External key service becomes a hard availability dependency. Engineer for high availability.
Health records, IHS and tribal health (Tier 1 to 2)	HIPAA regulated. Add Confidential Computing for data in active processing. Azure Managed HSM with Confidential VMs, or AWS CloudHSM Custom Key Store with Nitro Enclaves.	Azure Managed HSM (Marvell LiquidSecurity) is native; for HYOK use Thales or Fortanix.	Confirm the FIPS level and the confidential compute boundary for the specific service.
Language preservation and cultural archives (Tier 1)	Never store in standard cloud. HYOK with physical residency on tribal land via AWS Outposts, Azure Stack Hub, or Google Distributed Cloud. The Cherokee Nation August 2025 AI policy, requiring fluent speaker review, is a practical governance model.	Tribal HSM on tribal land; Thales or Entrust for hardware attestation of key origin.	Access governance and cultural review matter as much as the cryptography.
Financial and grants management (Tier 2)	Salesforce Standard Shield or AWS CMK is typically sufficient. HYOK is generally not required unless records contain enrollment adjacent data.	None required. Thales CipherTrust is optional for multi cloud key management from one control plane.	Reassess the tier if financial records begin to carry enrollment adjacent data.

Amazon Web Services | Key Management Options

Three options on the custody spectrum. XKS is the recommended posture for Sovereign Data.

Option	Custody model	Who creates the key	Where the key is stored	Provider technical access	CLOUD Act exposure to provider	HYOK (key never enters cloud)	FIPS status	Tribal key custody	Best-fit tier	Notes and limits
Standard KMS CMK	Customer managed; provider stores	AWS KMS multi tenant HSM, or customer import (BYOK)	AWS owned HSMs, distributed across Availability Zones	Yes	Moderate to High (BYOK does not remove it)	No	FIPS 140-3 Level 3 (cert #4884, Feb 2025)	Low	Tier 3	Deep integration across 100+ services. Automatic rotation. About \$1 per key per month. ML-DSA post quantum signatures generally available.
CloudHSM Custom Key Store	Single tenant HSM inside customer VPC	Customer, in a dedicated CloudHSM cluster	Customer owned CloudHSM cluster within the customer VPC	No independent access	Applies to AWS, but disconnecting the cluster is friction, not a shield	Partial (cluster sits within AWS)	FIPS 140-3 Level 3	Medium to High	Tier 2	Symmetric keys only. No asymmetric, HMAC, imported material, automatic rotation, or multi region keys. Cluster management errors can permanently destroy keys.
External Key Store (XKS)	Hold Your Own Key	Customer, entirely outside AWS	Customer external key manager; AWS holds only a reference	None	Low (AWS cannot comply; it holds no key material)	Yes (mature)	Set by the external HSM	High	Tier 1	AES-256 symmetric keys only. Customer operates and secures the XKS Proxy. Every operation is a network round trip; external outage halts access. Recommended for Sovereign Data tiers.

Microsoft Azure | Key Management Options

Anchored by Key Vault, with a hardware isolated Managed HSM and split key DKE for Microsoft 365.

Option	Custody model	Who creates the key	Where the key is stored	Provider technical access	CLOUD Act exposure to provider	HYOK (key never enters cloud)	FIPS status	Tribal key custody	Best-fit tier	Notes and limits
Key Vault Standard (software)	Customer managed; provider stores	Microsoft, or customer import (BYOK)	Azure software cryptographic modules in the customer tenant	Yes	High	No	FIPS 140-2 Level 1 (software only)	Low	Tier 3	Logging is off by default and must be enabled. Use Azure RBAC over legacy access policies. Enable purge protection to prevent irrecoverable deletion.
Key Vault Managed HSM	Single tenant HSM; provider cannot access	Customer, in a dedicated HSM pool	Three Marvell LiquidSecurity partitions; operations run inside Intel SGX enclaves	No (SGX boundary)	Low (order to Microsoft cannot reach key material)	Partial (confidential compute isolation)	FIPS 140-3 Level 3	High	Tier 2	Customer must protect the security domain backup. Losing it means permanent, irrecoverable loss of all keys. Not available in every region.
Purview Double Key Encryption (M365)	Split key; both keys persistent	Two keys: Microsoft holds one, customer holds one	Microsoft key in Azure Key Vault; customer key on customer infrastructure	Cannot decrypt alone	Low for Microsoft's copy alone	Split key	Inherits Key Vault and customer HSM	High (for M365 content)	Tier 1	Microsoft 365 workloads only. Both services must be reachable for every access. The customer key can be hosted on tribal land.
Confidential Computing (data in use)	Protection layer, not a key custody option	Not applicable	Hardware managed memory keys inside the TEE	No (hardware TEE)	Reduces in memory exposure to the provider	Not a key model	AMD SEV-SNP, Intel TDX, Intel SGX	Adds assurance	Tier 1 to 2	Broadest production deployment among major clouds. Pair with Managed HSM for health or enrollment data in active processing. NVIDIA H100 confidential GPU for AI workloads.

Google Cloud Platform | Key Management Options

Distinctive for Key Access Justifications, the only programmatic legal process defense among the major clouds.

Option	Custody model	Who creates the key	Where the key is stored	Provider technical access	CLOUD Act exposure to provider	HYOK (key never enters cloud)	FIPS status	Tribal key custody	Best-fit tier	Notes and limits
CMEK	Customer managed; provider stores	Customer, in Cloud KMS, or imported	Encrypted at rest in Google's distributed Keystore; Cloud HSM option available	Yes	Limited protection against orders to Google	No	Software Level 1; Cloud HSM FIPS 140-2 Level 3	Low to Medium	Tier 3	Disabling a key is reversible and is not crypto shredding. Scheduled destruction has a minimum 24 hour wait. Autokey has a free tier.
Cloud EKM with Key Access Justifications	Hold Your Own Key, plus policy based denial	Customer, in a third party KMS outside Google	Exclusively in the customer external key manager; Google holds a reference	None	Low; KAJ can auto deny requests tagged as third party legal process	Yes	Set by the external KMS	High	Tier 1	KAJ enforcement is supported only by Fortanix and Thales (Futorex does not). Use a private VPC connection. Effective availability is the lower of the two SLAs.
CSEK	Key supplied per call; never stored	Customer, entirely outside Google	Not stored; used transiently then purged	None	Very Low	Yes (per call)	Set by the customer environment	Very High (impractical)	Tier 1 note	Supported only for Cloud Storage and Compute Engine. No automatic rotation. Losing the key means permanent, irrecoverable data loss. Documented for completeness, not recommended.

Salesforce | Key Management Options

A SaaS model. Field level encryption with a Primary Secret and a customer Tenant Secret; EKM and Cache-Only add custody separation.

Option	Custody model	Who creates the key	Where the key is stored	Provider technical access	CLOUD Act exposure to provider	HYOK (key never enters cloud)	FIPS status	Tribal key custody	Best-fit tier	Notes and limits
Standard Shield	Key derived from Primary Secret plus Tenant Secret	Salesforce (Primary Secret) and customer (Tenant Secret)	Primary Secret in an air gapped HSM; Tenant Secret encrypted in the Salesforce database	Participates if the Tenant Secret is also compelled	Dual demand friction, but accessible if both are compelled	No	Embedded HSM FIPS 140-2 Level 2 (upgrade path unconfirmed; verify)	Medium	Tier 2	Tenant Secret destruction is permanent. Encryption can break reports, list views, and Apex; test first. Key limits apply.
BYOK	Customer generates; Salesforce stores after upload	Customer, uploaded to Shield KMS	Salesforce database, encrypted, after upload	Yes	High	No	Inherits Shield HSM	Low to Medium	Tier 2 to 3	Provides key origin attestation and rotation, not custody separation. Rotation available up to every 24 hours in production.
External Key Management (EKM)	Key fetched on demand; not persisted	Customer, in an external KMS	Customer external KMS; Salesforce stores only a reference	No	Low	Yes	Set by the external KMS	High	Tier 1	The external KMS becomes the sole cryptographic root of trust. Its security and availability are paramount.
Cache-Only Key	Key in memory only; never persisted	Customer, served into the in memory cache	In memory encrypted cache; never written to disk	No	Very Low	Yes	Set by the external KMS	High	Tier 1	Re fetched on every cache expiry and cluster restart. If the external key service is unavailable, all encrypted field operations halt at once for all users. Design for HA at or above Salesforce's SLA.